

Cyber Threats, Attack Vectors & Incident-Response Frameworks

Scenario: MediCasa — Regional Hospital Group
Lab 01

Name	HASSANI Mohammad Salem
Scenario	MediCasa — Regional Hospital Group (1,400 staff, on-premise EHR)
Student ID	2545880
Due	April 26, 2026
Instructor	Asen Grozdanov

Abstract

This report profiles the cyber-threat environment facing MediCasa, a fictional regional hospital group operating 1,400 staff and on-premise electronic health records (EHR) with limited cloud usage. Three realistic threat-actor categories are identified — ransomware affiliates, nation-state espionage groups, and malicious insiders — together with six plausible attack vectors drawn from the MITRE ATT&CK Enterprise matrix. An annotated attack-path diagram illustrates the spear-phishing-to-ransomware kill chain. Two incident-management frameworks — NIST SP 800-61 Rev. 3 (2025) and SANS PICERL — are compared across five dimensions; SANS PICERL is recommended as the better operational fit for MediCasa’s staffing constraints. The report concludes that mandatory multi-factor authentication (MFA) on all EHR access points is the single highest-return control MediCasa could deploy immediately.

Introduction

MediCasa is a fictional regional hospital group with 1,400 staff, on-premise EHR systems, and a hybrid posture: patient records remain on-site, while email and HR services run in the cloud. This profile places MediCasa squarely in the cross-hairs of financially motivated cybercriminals and, increasingly, espionage actors. The healthcare sector recorded more data breaches in 2024 than any previous year, affecting approximately 70% of the US population [1]. This report identifies MediCasa’s most plausible adversaries (Section A), maps their attack paths (Section B), compares two incident-response frameworks and recommends one (Section C), and closes with a single priority recommendation (Conclusion).

A Threats — Adversary Profiles

Weight: 2 / 10

A1. Ransomware-as-a-Service (RaaS) Affiliates

Organised cybercriminal groups that license ransomware payloads from developers and conduct attacks for a share of extortion proceeds. Groups such as LockBit 3.0 and the now-defunct ALPHV/BlackCat dominated healthcare targeting in 2023–2024, collectively accounting for more than 30% of all reported ransomware incidents in the sector [2].

Motivation: Financial gain — ransom payments and double-extortion (patient data sale).

Capability: High. RaaS operators invest in purpose-built tooling, 24/7 victim negotiation portals, and professional affiliates. Entry barrier for affiliates is low; operator infrastructure is sophisticated.

Real-world incident: ALPHV/BlackCat attacked Change Healthcare (February 2024), encrypting claims-processing systems and receiving approximately USD 22 million in ransom. The breach affected an estimated 190 million individuals [3].

A2. Nation-State Espionage Actors

Government-sponsored groups — primarily from Iran, China, and Russia — that target healthcare data for intelligence value: patient records on government officials, ongoing medical research, and pharmaceutical intellectual property. Espionage motives jumped from 1% to 16% of healthcare incidents in 2024 [4], signalling that MediCasa’s records may attract non-criminal actors.

Motivation: Espionage — health data on high-value targets; biomedical and pharmaceutical IP.

Capability: Nation-state. These actors possess zero-day capabilities, long-dwell persistence tooling, and resources to sustain multi-month campaigns undetected.

Real-world incident: CISA and HHS jointly warned of Lemon Sandstorm (Iran-nexus) actively targeting US health-sector networks in August 2024, exploiting valid credentials and VPN access [5].

A3. Malicious Insiders

Current or former staff with legitimate EHR credentials who misuse access for personal financial gain, grievance, or curiosity. Healthcare’s culture of broad record access — necessary for patient care — amplifies this risk. IBM reports that malicious insider attacks result in average losses of USD 4.92 million per incident [6].

Motivation: Financial gain (identity fraud, data resale on dark-web markets) or personal grievance.

Capability: Low-to-medium. No technical exploitation is required; the threat is authorisation abuse rather than vulnerability exploitation.

Real-world incident: University of Missouri Health Care suspended an employee who inappropriately accessed 736 patient EHR records between July 2021 and March 2023; the organisation paid a USD 240,000 HHS/OCR settlement [7].

B Attack Vectors Weight: 3 / 10

For each threat actor identified in Section A, two MITRE ATT&CK-aligned vectors are described below. All six are summarised in Table B-1 on the following page; the spear-phishing kill chain is illustrated in Figure 1.

Actor	Vector (MITRE ID)	Prerequisite	Defender Control	CIA
RaaS Affiliate	Spear-phishing with malicious attachment (T1566.001)	Valid staff email; knowledge of EHR vendor in use	Email sandbox; macro execution disabled by GPO; security-awareness training	C, I, A
RaaS Affiliate	Exposed RDP with stolen credentials (T1078, T1021.001)	Valid domain credentials; internet-exposed RDP or VPN endpoint	MFA on all remote access; network segmentation; EDR alert on unusual logon hours	C, A
Nation-State	Supply-chain update compromise (T1195.002)	Access to trusted EHR vendor software update pipeline	Software bill-of-materials (SBOM); vendor security assessments; update integrity checks	C, I
Nation-State	Watering-hole on clinical staff portal (T1189)	Knowledge of clinical intranet URL; ability to inject malicious JavaScript	Browser isolation; Content Security Policy headers; TLS-inspecting web proxy	C
Malicious Insider	Bulk EHR export to personal cloud storage (T1567.002)	Existing authorised EHR access; absence of DLP controls	Data-loss prevention (DLP); UEBA alerting on bulk record access; least-privilege roles	C
Malicious Insider	Credential sharing /	Knowledge of colleague's	Session timeout; user-behaviour analytics	C, I

Actor	Vector (MITRE ID)	Prerequisite	Defender Control	CIA
	account takeover (T1078.003)	credentials or access to unattended workstation	(UEBA); physical screen-lock enforcement	

Table B-1. Six attack vectors mapped to MITRE ATT&CK Enterprise v14. CIA column indicates the primary Confidentiality / Integrity / Availability property targeted.

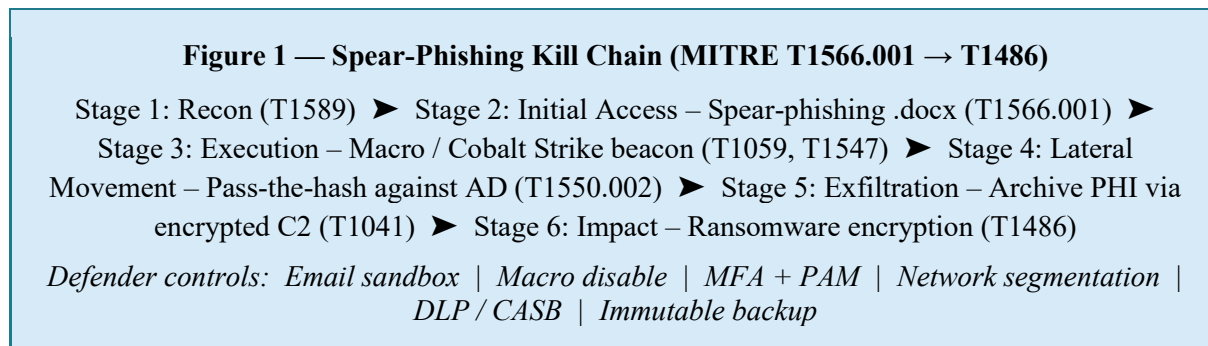


Figure 1. Spear-phishing attack path from initial reconnaissance to ransomware deployment at MediCasa. Own work, 2026-04-20. MITRE ATT&CK Enterprise v14 [8].

Vector narrative — RaaS spear-phishing. A RaaS affiliate purchases a MediCasa staff email list from a dark-web broker and crafts a message impersonating the EHR vendor’s support team. The attached .docx triggers a macro that drops a Cobalt Strike beacon (T1059.005). The attacker establishes persistence via a registry run key (T1547.001), escalates through pass-the-hash against Active Directory (T1550.002), exfiltrates a compressed archive of patient records over HTTPS (T1041), then deploys ransomware to all mapped drives (T1486). MediCasa’s on-premise EHR — lacking network segmentation and MFA — falls within minutes of lateral movement.

C	Incident-Response Frameworks	Weight: 3 / 10
----------	-------------------------------------	----------------

Two incident-management frameworks are compared below and one is recommended for MediCasa. Table C-1 presents the comparison across the five mandatory dimensions.

Dimension	NIST SP 800-61 Rev. 3 (April 2025)	SANS PICERL (2024 ed.)
Authoring body	National Institute of Standards and Technology (NIST), US Dept. of Commerce. Rev. 3 finalised April 2025; supersedes Rev. 2 (August 2012) [9].	SANS Institute — a private security-training and research organisation. PICERL model continuously maintained; 2024 curriculum edition referenced here [10].
Phases / functions	Aligned to six CSF 2.0 functions: Govern, Identify, Protect, Detect, Respond, Recover. Outcome-driven; no rigid linear lifecycle.	Six sequential phases: Preparation, Identification, Containment, Eradication, Recovery, Lessons Learned (PICERL). Linear with a mandatory review loop.
Scope	Voluntary best-practice guide; applicable across all sectors. Normative for US federal agencies under FISMA; widely adopted in healthcare.	Voluntary practitioner framework. No regulatory standing, but widely cited by SOC teams and DFIR professionals worldwide.

Dimension	NIST SP 800-61 Rev. 3 (April 2025)	SANS PICERL (2024 ed.)
Fit for MediCasa	Strong regulatory alignment (HIPAA, FISMA). CSF mapping suits board-level risk reporting. Less prescriptive for a small IR team under pressure.	Highly prescriptive phase-by-phase playbooks suit MediCasa's limited IT staff. Lessons-Learned phase drives continuous improvement — critical for low-maturity teams.
Cost and effort	Medium. Requires mapping existing controls to CSF 2.0 categories. Consulting or training cost if starting from scratch; significant documentation overhead.	Low-to-medium. Training materials freely available via SANS. Playbooks can be built incrementally. Faster time-to-value for a small team.

Table C-1. Framework comparison across five dimensions. NIST SP 800-61 Rev. 3 (April 2025) [9] vs SANS PICERL (2024 ed.) [10].

Recommendation: SANS PICERL

SANS PICERL is the better operational fit for MediCasa for three reasons. First, the six distinct phases give a small, generalist IT team an unambiguous checklist to follow during a live ransomware incident — exactly the scenario MediCasa must prepare for. NIST SP 800-61 Rev. 3’s CSF-aligned model is more powerful for mature organisations but risks becoming abstract under the pressure of a 03:00 call-out. Second, PICERL’s dedicated Lessons-Learned phase structures the post-incident review that MediCasa needs to improve iteratively. Third, SANS training materials are freely available, making adoption realistic within MediCasa’s constrained budget. That said, MediCasa should adopt the NIST SP 800-61 Rev. 3 Govern and Identify functions as a complementary layer once PICERL playbooks are operational, ensuring alignment with HIPAA breach-notification requirements [11].

D Conclusion Weight: 2 / 10

MediCasa faces a credible, high-probability threat from RaaS affiliates whose primary attack chain runs through phishing, stolen credentials, and unprotected RDP — all of which succeed only when multi-factor authentication is absent. Nation-state actors and insiders compound the risk but require more tailored controls: vendor SBOM reviews and UEBA monitoring, respectively.

Single priority action. If MediCasa could implement one change next Monday, it should mandate MFA on all EHR access points — both remote (VPN, RDP) and internal workstations.

This single control breaks the two most plausible attack chains simultaneously: it defeats RDP brute-force and credential-stuffing by RaaS affiliates (Vector B2), and it prevents account takeover by malicious insiders sharing passwords (Vector B6). The CISA advisory on ALPHV/BlackCat explicitly notes that the February 2024 Change Healthcare breach exploited a Citrix portal with no MFA [3]. MediCasa’s on-premise EHR is similarly exposed. MFA deployment requires no new hardware (software TOTP tokens suffice), costs under USD 5 per user per month on commodity platforms, and can be rolled out within two weeks. Every other control in this report — network segmentation, DLP, UEBA — is valuable but assumes an attacker is already inside; MFA is the door lock.

References

- [1] Rubrik Security Lab. Healthcare Cybersecurity Challenges & Threats 2025. Rubrik, 2025. <https://www.rubrik.com/insights/healthcare-cybersecurity-challenges-threats-2025>
- [2] Silobreaker Threat Intelligence. The Digital Pandemic: Ransomware Attacks on the Healthcare Sector. March 2025. <https://www.silobreaker.com/blog/healthcare/ransomware-attacks-on-the-healthcare-sector/>
- [3] CISA / FBI / HHS. #StopRansomware: ALPHV Blackcat. Advisory AA23-353A, updated February 2024. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-353a>
- [4] Verizon. 2024 Data Breach Investigations Report. Verizon Business, 2024. <https://www.verizon.com/business/resources/reports/dbir/>
- [5] Microsoft Security Insider. US Healthcare: Strengthening Against Ransomware. 2024. <https://www.microsoft.com/en-us/security/security-insider/emerging-threats/us-healthcare-at-risk-strengthening-resiliency-against-ransomware-attacks>
- [6] SentinelOne. Cybersecurity in Healthcare: Risks, Best Practices & Frameworks. 2026. <https://www.sentinelone.com/cybersecurity-101/cybersecurity/cybersecurity-in-healthcare/>
- [7] Becker's Hospital Review. 3 Hospitals, Health Systems Affected by Insider Breaches. <https://www.beckershospitalreview.com/cybersecurity/3-hospitals-health-system-affected-by-insider-breaches.html>
- [8] MITRE ATT&CK. Enterprise Matrix v14. <https://attack.mitre.org/>
- [9] NIST. SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. April 2025. <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
- [10] SANS Institute. Incident Handler's Handbook. 2024 edition. <https://www.sans.org/white-papers/33901/>